

Course: Information Assurance and Security

Lab Title: Assignment #1

Group Members: Joshua II B Dajao, Vonzelle Cuizon

Date:

Instructor: Engr. Godwin Monserate

1. Enumerate and identify the definition or focus of the different Federal organizations that defined Information Assurance. (5 pts)

1. Department of Defense (DoD)

The DoD defines Information Assurance (IA) as measures that protect and defend information and information systems by ensuring their availability, integrity, authentication, confidentiality, and non-repudiation. Its focus is on ensuring mission assurance in both peacetime and wartime operations.

2. National Security Agency (NSA)

The NSA provides national leadership in securing information systems for national security. Its IA mission includes developing cryptographic solutions, managing secure communications, and protecting against cyber threats targeting U.S. government systems.

3. National Institute of Standards and Technology (NIST)

NIST develops and promotes cybersecurity standards, guidelines, best practices, and frameworks (e.g., NIST Cybersecurity Framework) to improve information assurance in both federal agencies and private sectors.

4. Department of Homeland Security (DHS)

DHS is responsible for securing the nation's critical infrastructure, including cyberspace. Through the Cybersecurity and Infrastructure Security Agency (CISA), it provides risk management guidance and response coordination for cyber incidents.

5. Federal Bureau of Investigation (FBI)

The FBI investigates cybercrimes, including cyber espionage, terrorism, and intellectual property theft. It contributes to information assurance through criminal enforcement and threat intelligence.

2. What is an asset? Why is it worth protecting? (5 pts)

An **asset** is any data, device, system, process, or individual that has value to an organization. In the context of information assurance, assets include information systems, software, hardware, personnel, intellectual property, and business processes.

Assets must be protected because they are integral to:

- Achieving organizational goals
- Ensuring continuity of operations
- Safeguarding privacy and data integrity
- Preventing financial loss, reputational damage, or legal liabilities

In cybersecurity, the compromise of even a single asset can lead to cascading impacts on an organization's security posture.

3. Can you specify examples for objects, subjects, and (aside from the given)? (10 pts)

In access control and system security:

- **Subjects** are active entities that request access to resources (i.e., initiators of actions).

Examples:

- System administrators executing commands
- Automated processes (cron jobs, system daemons)
- End-users using client applications

- **Objects** are passive entities that contain or receive information.

Examples:

Configuration files

- Shared network drives
- Web application databases
- APIs receiving and processing data

By distinguishing subjects and objects, we can enforce the principle of least privilege and access control models such as DAC, MAC, and RBAC.

4. Enumerate and give examples for the different types of threat. (10 pts)

1. Natural Threats

- Earthquakes, typhoons, floods
- Example: A data center flooding due to a storm, causing data loss

2. Environmental Threats

- Power failure, HVAC malfunction, humidity
- Example: Server overheating due to cooling system failure

3. Human Threats – Intentional

- Hackers, cyber terrorists, disgruntled employees
- Example: Insider sabotaging a database intentionally

4. Human Threats – Unintentional

- Mistakes, negligence, misconfigurations
- Example: Employee accidentally deleting customer records

5. Technological Threats

- Software vulnerabilities, malware, outdated firmware
- Example: Ransomware exploiting an unpatched operating system

Understanding these threats allows organizations to perform proper risk analysis and mitigation planning.

5. Describe the local enclave of the University of San Carlos. (10 pts)

The **local enclave** of the **University of San Carlos (USC)** refers to the protected, internal segment of its information infrastructure. It is a logically and physically secured domain where trusted resources operate under strict access controls and policies.

Key components include:

- Academic and administrative servers (e.g., student records, finance systems)
- Computer laboratories and research systems
- Secure Wi-Fi and wired networks across campuses
- Firewalls, intrusion detection systems (IDS), and endpoint security
- Campus portals (e.g., iUSC) with authentication mechanisms
- Data backup systems and IT support infrastructure

The enclave ensures that university data is kept confidential, available, and accurate for students, faculty, and administrators.

6. Differentiate exploit and attack. (5 pts)

- **Exploit:** A piece of software, script, or command sequence that takes advantage of a vulnerability in a system.
Example: Using an SQL injection payload to extract unauthorized data.
- **Attack:** A deliberate action aimed at compromising a system's confidentiality, integrity, or availability.
Example: A DDoS attack on a university website to make it inaccessible.

In short: An exploit is a tool or technique; an attack is the action or event that may use one or more exploits.

7. Can you give examples of dangling vulnerability and dangling threat or any situation which might occur? (5 pts)

- **Dangling Vulnerability:** A security flaw in a system or asset that is no longer actively used but is still accessible.
Example: An old FTP server still running with default credentials.
- **Dangling Threat:** A threat actor or condition that remains even after the related system or resource has been decommissioned.
Example: An attacker retaining access through leftover administrator credentials after a system migration.

These oversights can create backdoors for exploitation and highlight the need for thorough decommissioning and audit practices.

8. Try to follow this procedure to manage risks to your material possessions stored at your home or apartment. Give at least 15 potential hazards or threats. (15 pts)

Potential Hazard or Risk	Persons Who May Be Harmed	Property That May Be Damaged	Risk Control / Mitigation Plan	Risk Rating	Further Action Needed
Theft	Residents	Electronics, valuables	Secure doors/windows, CCTV	High	Alarm system
Fire	All occupants	Entire home	Smoke alarms, fire extinguisher	High	Fire drills, inspection
Earthquake	All occupants	Structural damage	Reinforced walls, emergency kit	Medium	Earthquake drills
Power Outage	All occupants	Electronics, data loss	UPS, surge protectors	Medium	Backup generator
Water Leak	Residents	Floors, electronics	Regular plumbing checks	Medium	Water sensors
Gas Leak	Residents	Health, fire risk	Gas detectors, maintenance	High	Automatic shut-off valve
Cyber Intrusion (Wi-Fi)	All	Data, privacy	Strong passwords, WPA3	High	Network segmentation

Identity Theft	All	Personal information	Shred documents, secure storage	High	Password management tools
Physical Injury (Slip)	All	Health	Non-slip mats	Medium	Hazard signage
Mold Growth	All	Health, interior	Dehumidifiers, ventilation	Medium	Mold inspection
Electrical Fire	All	Home wiring	Professional wiring checks	High	Circuit breakers
Intrusion via Windows	Residents	Valuables	Window bars, locks	High	Motion detectors
Data Loss	Residents	Laptops, hard drives	Cloud backups	Medium	Automated backup schedule
Pet Escaping	Residents	Pets	Fencing, microchipping	Low	GPS pet collar
Stranger Access (Tailgating)	Residents	Safety, property	Gated entry, intercom system	Medium	Educate household members

9. There is generally more money in a bank than in a convenience store; but which is more likely to be robbed? Why? Which risk management technique is this an instance of? (5 pts)

A convenience store is more likely to be robbed due to:

- Lower security presence
- Easier access and escape
- Less risk for the criminal

This scenario exemplifies the **risk management technique of Risk Assessment**, particularly focusing on **likelihood vs. impact**. Although a bank has more assets, its security measures deter attacks, thereby reducing its likelihood of being targeted. This also reflects Risk Mitigation in the form of layered security, and Risk Avoidance by making targets unattractive.

10. Develop a waterfall model for the security systems lifecycle management. Explain each of the stages. (10 pts)

Waterfall Model for Security Systems Lifecycle Management:

1. Requirements Analysis

Define security needs based on legal, organizational, and operational requirements. Example: compliance with GDPR or ISO 27001.

*(frameworks that protect data and guide organizations in managing information securely; GDPR focuses on **privacy rights**, while ISO 27001 ensures **structured security practices**).*

2. System Design

Architect the security solution by identifying necessary components such as firewalls, intrusion detection systems (IDS), access control models, and network segmentation.

A DMZ (Demilitarized Zone) can be designed to isolate publicly accessible services (e.g., web and mail servers) from the internal network, reducing the risk of lateral movement by attackers.

This phase defines how internal, external, and segmented network zones communicate securely.

3. **Implementation**

Deploy hardware/software and configure according to design. This includes setting up access control, patching systems, and integrating into existing infrastructure.

4. **Testing and Evaluation**

Perform penetration testing, vulnerability scanning, and audits. Ensure system meets security requirements without impacting performance.

5. **Deployment**

Roll out the system into production with final configurations. Ensure proper user training and documentation.

6. **Operations and Maintenance**

Ongoing monitoring, updates, log management, and incident response. Regular patching and user access reviews are key.

7. **Disposition (Decommissioning)**

Securely decommission outdated systems. Wipe data, remove credentials, and eliminate lingering vulnerabilities.

This lifecycle ensures security is embedded from planning through end-of-life, reducing risk and improving organizational resilience.

○